

Audit de cybersécurité de code logiciel par IA dans un environnement maîtrisé

Contexte

BlueTrusty propose une analyse de sécurité du code logiciel mis à sa disposition par le client. L'objectif est d'identifier les vulnérabilités et les scénarios de risque qui méritent une correction ou une investigation complémentaire, puis de les restituer dans un rapport exploitable.

L'intervention s'adresse notamment aux applications métier, aux API, aux composants exposés, aux produits en préparation et aux patrimoines logiciels qui concentrent des enjeux de confidentialité ou de disponibilité.

Elle est particulièrement adaptée aux organisations qui ne souhaitent pas exposer leur base de code à des services externes, afin de préserver la confidentialité et leur propriété intellectuelle. Elle répond aussi aux cas où l'usage d'outils d'IA en cloud reste inacceptable, y compris lorsque ces outils proposent une configuration ZDR, ou *Zero Data Retention*.

Ces préoccupations rejoignent la [controverse récente autour de travaux mathématiques non publiés et des conditions dans lesquelles OpenAI aurait pu en avoir connaissance](#). Les faits sont contestés, mais cet épisode rappelle l'importance de maîtriser précisément où circulent le code, les échanges et les résultats de recherche.

Un audit de code adapté aux environnements sensibles

Le code source, les dépendances, les configurations et la documentation utile sont étudiés dans une enclave située en Union européenne. Le matériel IA mobilisé est réservé à cette fonction. L'analyse ne repose pas sur un service d'IA cloud mutualisé. En aucun cas, une partie du code ne sera exfiltrée ni transmise à une IA ou à tout autre service extérieur à l'enclave.

Notre environnement d'audit n'est pas une plateforme multi-tenante ni un espace de travail partagé entre plusieurs clients. À un moment donné, chaque enclave est dédiée à l'analyse du code, des dépendances et des configurations d'un seul client, dans un environnement isolé et contrôlé. Les flux entrants sont placés sous le contrôle d'une architecture réseau ZTNA. Les flux sortants sont journalisés au niveau applicatif au moyen d'une interception TLS effectuée localement. Le modèle ne dispose d'aucun chemin de sortie alternatif : toute communication vers l'extérieur doit passer par le proxy d'interception, selon les règles autorisées et journalisées. Cette conception s'inspire des principes NVIDIA relatifs aux environnements d'exécution isolés, à la séparation des workloads et au contrôle des flux sortants.



DGX Spark — image : [IAMNUC](#).

Le périmètre de l'audit cyber de code est défini avant le transfert. Les modalités de remise, les règles de manipulation et le canal de restitution sont convenus avec le client afin de s'aligner sur ses contraintes de confidentialité.

Selon le volume du périmètre, l'enclave s'appuie sur des capacités NVIDIA, notamment des puces Blackwell ou des châssis DGX. Elle peut utiliser du matériel déjà détenu par BlueTrusty et exploité dans un environnement cloisonné et maîtrisé. Elle peut aussi recourir à la location à l'heure de capacités matérielles brutes auprès d'opérateurs d'infrastructure en tant que service (IaaS), soit qualifiés SecNumCloud, soit hébergeant ces capacités dans l'Union européenne. Dans ce cas, les ressources sont réservées à l'audit et intégrées à l'enclave, sans recours à un service d'IA mutualisé. Le choix de l'infrastructure, de l'opérateur et des modalités d'exploitation est présenté au client et validé par lui avant tout audit.

Les interactions éventuellement nécessaires avec Internet, par exemple pour consulter une documentation technique ou télécharger un outil spécifique, passent par un sas de sécurité et d'inspection dédié. Les destinations autorisées relèvent d'une liste blanche stricte et particulièrement surveillée. Tous les échanges qui traversent ce sas sont journalisés. Ce contrôle des flux sortants vise à prévenir toute transmission non autorisée de code, de données ou de propriété intellectuelle hors de l'enclave.

Une plateforme d'IA spécialement entraînée pour l'analyse de code logiciel

Les vulnérabilités se révèlent souvent dans les relations entre composants plutôt que dans une instruction isolée. L'analyse examine donc les flux de données, les contrôles d'accès, les secrets, les dépendances et les hypothèses de configuration qui peuvent former un chemin d'attaque plausible.

Pour l'analyse des applications Java, l'enclave s'appuie sur une chaîne SAST entièrement exécutée localement. SpotBugs et Find Security Bugs assurent une analyse spécialisée du bytecode Java, complétée par Semgrep et un corpus de règles Java, Spring et Jakarta versionné dans l'environnement d'audit. Les résultats sont normalisés, dédoublés et corrélés avec le graphe du code avant leur qualification par les modèles et leur validation par les auditeurs. Ni le code source, ni le bytecode, ni les résultats d'analyse ne sont transmis à un service cloud.

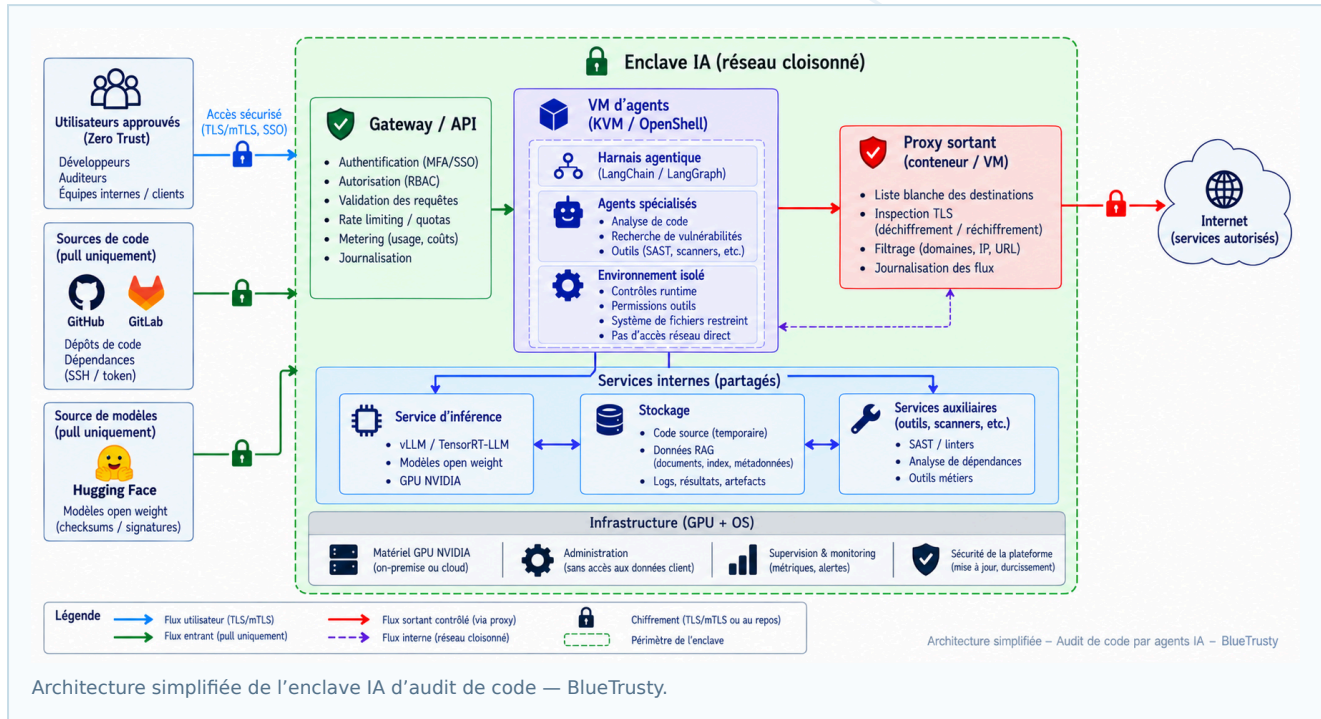
Plusieurs agents spécialisés travaillent en parallèle sur les zones les plus pertinentes du périmètre. Cette organisation permet de traiter de grandes bases de code sans limiter l'investigation à quelques fichiers ou à une lecture séquentielle.

Le harnais qui orchestre l'audit est open source. Il n'est pas fourni par l'éditeur du modèle de langage utilisé, ce qui permet de maîtriser séparément l'orchestration de l'analyse et le choix du modèle.

Le dispositif utilise du matériel IA de dernière génération et un modèle frontière de type MoE à poids ouverts (*open weight*), fine-tuné à partir de nos audits anonymisés et d'une documentation cybersécurité sélectionnée.

Tous nos rapports d'audit et travaux de recherche sont anonymisés, puis conservés dans un espace de stockage raw dédié et indexés dans une base de connaissances de type RAG (*Retrieval-Augmented Generation*). Cette base est mise à la disposition du LLM à l'intérieur de l'enclave. Pendant l'investigation, le modèle retrouve les analyses, scénarios de risque et pistes de correction pertinents issus de cette expérience accumulée. Le fine-tuning adapte ses capacités ; le RAG lui apporte des connaissances consultables au moment de l'audit, ce qui renforce la portée du moteur d'audit cyber. Nos équipes d'experts rapprochent, contextualisent et structurent ensuite les résultats produits par les agents pour former une vue cohérente des risques.

Déroulé de l'audit



L'audit s'appuie sur les cadres méthodologiques et les référentiels du NIST, de MITRE et de l'OWASP, sélectionnés selon la nature du logiciel examiné. Ils guident la conduite de l'investigation, la classification des faiblesses et la vérification des contrôles de sécurité applicables.

- Cadrage.** Définition du périmètre, des composants sensibles, des hypothèses de menace et des attentes de restitution.
- Cartographie et planification.** Lecture de l'architecture, des frontières de confiance, des dépendances et des flux qui portent les données sensibles.
- Investigation.** Recherche des faiblesses et des enchaînements qui pourraient être exploités dans le contexte applicatif.
- Qualification.** Mise en perspective de chaque constat selon son impact potentiel, sa plausibilité et sa priorité de traitement.
- Restitution.** Présentation des résultats aux décideurs et aux équipes techniques afin de préparer les remédiations.

L'équipe BlueTrusty construit l'environnement de test avant l'audit, puis le démantèle de façon sécurisée à l'issue de la mission. Elle assure les échanges avec le client, conduit les entretiens nécessaires et présente les résultats. Elle analyse et qualifie les rapports produits avec l'assistance de l'IA : les conclusions reposent ainsi sur une lecture argumentée, supervisée et assumée par l'équipe.

Un rapport conçu pour la décision et la correction

Le rapport, réalisé avec l'assistance de l'IA dans cet environnement maîtrisé, distingue les constats selon leur niveau de priorité. Pour chacun, il précise le contexte concerné, le scénario de risque, l'impact potentiel, les éléments de preuve utiles et une orientation de remédiation. Une synthèse facilite les arbitrages de pilotage, tandis que les équipes techniques disposent des informations nécessaires pour organiser les corrections.

Des annexes techniques détaillées accompagnent le rapport. Elles peuvent notamment présenter des propositions de correction de code, afin d'aider les équipes à préparer et à accélérer les remédiations.

Une restitution permet ensuite d'échanger sur les conclusions, de préciser les points sensibles et de définir les prochaines étapes.

Cadre, limites et référentiels

L'IA apporte une capacité d'exploration adaptée aux périmètres étendus et accélère l'investigation. Le service ne constitue pas une certification du logiciel ni une garantie d'absence de vulnérabilité. Les résultats sont communiqués dans le cadre précis du périmètre audité et des éléments mis à disposition.

Les référentiels méthodologiques mentionnés dans cette offre sont accessibles ici :

- [NIST SP 800-115: Technical Guide to Information Security Testing and Assessment](#)
- [NIST SP 800-218: Secure Software Development Framework \(SSDF\) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities](#)
- [MITRE CWE: Common Weakness Enumeration](#)
- [MITRE CAPEC: Common Attack Pattern Enumeration and Classification](#)
- [OWASP Code Review Guide](#)
- [OWASP Application Security Verification Standard \(ASVS\)](#)
- [NVIDIA Enterprise Reference Architectures](#)

À propos de [bluetrusty.ai](#)

BlueTrusty est certifié ISO 27001. Son approche des infrastructures IA maîtrisées est présentée dans les formations et l'article suivants :

- [Formation ORSYS : Plateforme IA d'entreprise, construire une architecture hybride](#)
- [Formation Institut Capgemini : construire sa plateforme IA d'entreprise souveraine et maîtrisée](#)
- [Article ChannelNews : ITS Group formalise une offre d'accompagnement à la construction de plateformes IA souveraines](#)

Version 1.3 · Contact : contact@bluetrusty.com